

Corso Epicode

ANALISI DELLE VULNERABILITA' ED AZIONI DI RIMEDIO

Report a cura di Valentino Pizzi
27 settembre, 2025

Obbiettivo:

- Mitigare 2-4 vulnerabilita' critiche in metasploitable IP '192.168.50.101

Contenuti:

- Vulnerabilita' scelte
 - Analisi e Mitigazione
-

Obbiettivo:

Analizzare le vulnerabilita' scovate con Nessus e trovare un modo per mitigarle.

Bind Shell Backdoor Detection

Diagnosi

L'Host puo' essere compromesso da una shell remota.

Descrizione

Una shell e' in ascolto in una porta senza credenziali di accesso. Unn attaccante puo' usarla per connettersi ed eseguire comandi da remoto.

Soluzione

Verificare se l'Host e' stato compromesso, e reinstallare il sistema se necessario.

In caso contrario scovare la backdoor e chiuderla.

Fattore di Rischio

Critico

CVSS v3.0 Base Score 9.8

(CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CVSS v2.0 Base Score 10.0

CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

Informazioni di Plugin

Pubblicato: 2011/02/15, Modificato: 2022/04/11

Uscita Plugin

tcp/1524/wild_shell

```

Session  Actions  Edit  View  Help

type      = INTERNAL
id         = echo-dgram
socket_type = dgram
protocol   = udp
user       = root
wait       = yes
}
root@metasploitable:/home/msfadmin# cat /etc/xinetd.d/
chargen daytime discard echo time vsftpd
root@metasploitable:/home/msfadmin# cat /etc/xinetd.d/vsftpd
# default: on
# description:
#   The vsftpd FTP server serves FTP connections. It uses
#   normal, unencrypted usernames and passwords for authentication.
# vsftpd is designed to be secure.
service ftp
{
    socket_type      = stream
    wait             = no
    user             = root
    server           = /usr/sbin/vsftpd
    server_args      =
    # log_on_success  += DURATION USERID
    # log_on_failure  += USERID
    nice             = 10
    disable          = no
}

root@metasploitable:/home/msfadmin# grep -Er ingreslock /etc
grep: /etc/alternatives/vncpasswd.1.gz: No such file or directory
/etc/services:ingreslock    1524/tcp
/etc/services:ingreslock    1524/udp
grep: warning: /etc/tomcat5.5/tomcat5.5: recursive directory loop

/etc/inetd.conf:ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/home/msfadmin# cat /etc/inetd.conf
#<off># netbios-ssn    stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/smbd
telnet    stream tcp    nowait  telnetd /usr/sbin/tcpd    /usr/sbin/in.telnetd
#<off># ftp           stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.ftpd
tftp      dgram  udp      wait    nobody  /usr/sbin/tcpd    /usr/sbin/in.tftpd /srv/tftp
shell     stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.rshd
login     stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.rlogind
exec      stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.rexecd
ingreslock stream tcp nowait root /bin/bash bash -i
root@metasploitable:/home/msfadmin# nano /etc/inetd.conf
Error opening terminal: xterm-256color.
root@metasploitable:/home/msfadmin# vim /etc/inetd.conf
#<off># netbios-ssn    stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/smbd
#telnet    stream tcp    nowait  telnetd /usr/sbin/tcpd    /usr/sbin/in.telnetd
#<off># ftp           stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.ftpd
tftp      dgram  udp      wait    nobody  /usr/sbin/tcpd    /usr/sbin/in.tftpd /srv/tftp
shell     stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.rshd
login     stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.rlogind
exec      stream tcp    nowait  root    /usr/sbin/tcpd    /usr/sbin/in.rexecd
ingreslock stream tcp nowait root /bin/bash bash -i
~
~
~
~
~
~
~

```

Connettendosi a metasploitable tramite telnet ho indagato sul processo aperto nella porta 1524, comprendendo essere un file di sistema chiamato “xinetd”, cancellarlo avrebbe creato problemi alla macchina perciò ho indagato sul nome del processo “ingreslock” scopando così’ dove esso si nascondeva, una volta scovato e’ bastato commentare la riga di comando per disattivare la backdoor.

VNC Server 'password' Password

Diagnosi

Un server VNC gira in remoto con una password scadente.

Descrizione

Il server VNC sta girando con una password “password”.Nessus e’ stata in grado di autenticarsi per via della password scadente. Da remoto, un attaccante non autorizzato puo’ sfruttare questa vulnerabilita’ per prendere il controllo del sistema.

Soluzione

Cambiare la password VNC aumentandone così’ la sicurezza.

Fattore di Rischio

Critico

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

Informazioni Plugin

Publicato: 2012/08/29, Modificato: 2015/09/24

Uscita Plugin

tcp/5900/vnc

```
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Password too short
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
Password too short
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
Warning: password truncated to the length of 8.
Verify:
Passwords do not match. Please try again.

Password:
Warning: password truncated to the length of 8.
Verify:
root@metasploitable:~# █
```

Dopo esserci connessi alla metasploitable da telnet, cerchiamo informazioni su VNC, come funziona e come cambiare password, cercando scopriamo che basta essere root e usare il comando “vncpasswd”, fatto cio’ cambiamo password e cosi’ il problema e’ risolto.
